

Personal Data Protection Act Compliance Reference 04 — Data Subject Access Request (DSAR) Cross-Reference Table (Global CBPR Edition)

適用法規：個人資料保護法（2025.11.11 修正公布）及施行細則（2016 年現行法） / Global CBPR System Program Requirements Enforcement Map for Chinese Taipei（Annex B）

Applicable law: Personal Data Protection Act (amended 2025.11.11) and its Enforcement Rules (2016) | Global CBPR System Program Requirements Enforcement Map for Chinese Taipei (Annex B)

【使用說明】

本表為獨立 DSAR 對照表（04 文件），供 01 AI Prompt 路徑 B（當事人近用請求應對）使用，不需搭配 02 法規盤點對照表。產出結果應包含【壹、DSAR 程序通用基礎（適用所有五項權利）】＋【貳/參/肆/伍/陸】（視 user 指令）＋【柒、DSAR 紀錄保存與稽核（適用所有五項權利）】。

「GCBPR 計畫要求」欄標示所屬隱私原則（粗體藍字）及問題編號與中文問題全文，取自中英文對照版 Enforcement Map（Annex B）。「—」= 無直接對應條文。

This standalone DSAR table supports 01 AI Prompt Path B (data subject access request handling) and does not require Document 02. The "GCBPR Program Requirements" column cites the relevant Privacy Principle and question number(s) verbatim from the Global CBPR Annex B Enforcement Map (English original).

個資法依據	個資法條文	施行細則對應條文	佐證文件／資料	GCBPR Program Requirements
壹、DSAR 程序通用基礎（適用所有五項權利）				
◆ 個資法第 3 條（當事人不可拋棄之五項權利）	當事人就其個人資料依本法規定行使之下列權利，不得預先拋棄或以特約限制之：一、查詢或請求閱覽。二、請求製給複製本。三、請求補充或更正。四、請求停止蒐集、處理或利用。五、請求刪除。	—	個人存取更正程序文件	[Access and Correction] Q36: Upon request, do you provide confirmation of whether or not you hold personal information about the requesting individual? Q37: Upon request, do you provide individuals access to the personal information that you hold about them? 37a) Do you take steps to confirm the identity of the individual requesting access? 37b) Do you provide access within a reasonable time frame following an individual's request for access? 37c) Is information communicated in a reasonable manner that is generally understandable? 37d) Is information provided in a way that is compatible with the regular form of interaction with the individual? 37e) Do you charge a fee for providing access? Q38: Do you permit individuals to challenge the accuracy of their information, and to have it rectified, completed, amended and/or deleted? 38a) Are your access and correction mechanisms presented in a clear and conspicuous manner? 38b) If an individual demonstrates that personal information about them is incomplete or incorrect, do you make the requested correction, addition, or where appropriate, deletion? 38c) Do you make such corrections or deletions within a reasonable time frame following an individual's request? 38d) Do you provide a copy of the corrected personal information, or confirmation that it has been corrected or deleted? 38e) If access or correction is refused, do you notify the individual with an explanation and contact information for further inquiries?
◆ 個資法第 13 條（受理期限與費用）	公務機關或非公務機關受理當事人依第三條規定之請求，應於收受請求後十五日內，為准駁之決定；必要時，得予延長，延長之期間不得逾十五日，並應將其原因以書面通知當事人。公務機關或非公務機關受理當事人前項請求，得酌收必要成本費用。	—	個人存取更正程序文件	[Access and Correction] Q37: Upon request, do you provide individuals access to the personal information that you hold about them? 37a) Do you take steps to confirm the identity of the individual requesting access? 37b) Do you provide access within a reasonable time frame following an individual's request for access? 37c) Is information communicated in a reasonable manner that is generally understandable? 37d) Is information provided in a way that is compatible with the regular form of interaction with the

個資法依據	個資法條文	施行細則對應條文	佐證文件／資料	GCBPR Program Requirements
				individual? 37e) Do you charge a fee for providing access?
◆ 個資法第 10 條（協助義務與拒絕事由）	公務機關或非公務機關應就當事人依第三條規定，就其個人資料之查詢或請求閱覽、製給複製本、補充或更正、停止蒐集、處理或利用、刪除，給予必要之協助。公務機關或非公務機關得就下列情形，對當事人依第三條第四款或第五款之請求，為拒絕之決定：一、妨害國家安全、外交及軍事機密、整體經濟利益或其他國家重大利益者。二、妨害公共利益者。三、妨害公務機關執行法定職務者。四、妨害蒐集機關或第三人之重大利益者。	—	適用法律／法規要求文件	[Access and Correction] Q38: Do you permit individuals to challenge the accuracy of their information, and to have it rectified, completed, amended and/or deleted? 38a) Are your access and correction mechanisms presented in a clear and conspicuous manner? 38b) If an individual demonstrates that personal information about them is incomplete or incorrect, do you make the requested correction, addition, or where appropriate, deletion? 38c) Do you make such corrections or deletions within a reasonable time frame following an individual's request? 38d) Do you provide a copy of the corrected personal information, or confirmation that it has been corrected or deleted? 38e) If access or correction is refused, do you notify the individual with an explanation and contact information for further inquiries?
◆ 個資法第 27 條第 1 項（安全措施義務）	非公務機關保有個人資料檔案者，應採行適當之安全措施，防止個人資料被竊取、竄改、毀損、滅失或洩漏。	◆ 施行細則第 12 條第 2 項第 5 款：五、個人資料蒐集、處理及利用之內部管理程序。	個人資料處理活動紀錄	[Accountability] Q39: What measures do you take to ensure compliance with the Global CBPR Privacy Principles? (Internal guidelines or policies / Contracts / Compliance with applicable industry or sector laws and regulations / Compliance with self-regulatory Applicant Organization code and/or rules / Other)
		◆ 施行細則第 12 條第 2 項第 7 款：七、認知宣導及教育訓練。	員工隱私教育訓練紀錄	[Accountability] Q44: Do you have procedures in place for training employees with respect to your privacy policies and procedures, including how to respond to privacy-related complaints?
		◆ 施行細則第 12 條第 2 項第 9 款：九、資料安全稽核機制。	不符合事項及矯正措施紀錄	[Accountability] Q41: Do you have procedures in place to receive, investigate and respond to privacy-related complaints? Q42: Do you have procedures in place to ensure individuals receive a timely response to their complaints? Q43: If YES to Q42, does this response include an explanation of remedial action relating to their complaint?
		◆ 施行細則第 12 條第 2 項第 10 款：十、使用紀錄、軌跡資料及證據保存。	稽核計畫及稽核結果紀錄	[Security Safeguards] Q27: Describe the physical, technical and administrative safeguards you have implemented to protect personal information against risks such as loss or unauthorized access, destruction, use, modification or disclosure of information or other misuses. Q30: Have you implemented safeguards that are proportional to the likelihood and severity of the harm threatened, the sensitivity of the information, and the context in which it is held, through: 30a) Employee training and management or other safeguards? 30b) Information systems and management, including network and software design, as well as information processing, storage, transmission, and disposal? 30c) Detecting, preventing, and responding to attacks, intrusions, or other security failures? 30d) Physical security?

個資法依據	個資法條文	施行細則對應條文	佐證文件／資料	GCBPR Program Requirements
◆ 個資法第 8 條第 1 項第 5 款（預先告知 DSAR 管道）	非公務機關向當事人蒐集個人資料時，應明確告知當事人：五、當事人依第三條規定得行使之權利及方式。	◆ 施行細則第 16 條： 依本法第八條、第九條及第五十四條所定告知之方式，得以言詞、書面、電話、簡訊、電子郵件、傳真、電子文件或其他足以使當事人知悉或可得知悉之方式為之。	隱私聲明／告知事項文件	[Notice] Q1: Do you provide clear and easily accessible statements about your practices and policies that govern the personal information described above (a privacy statement)? Q1a: 1a) Does this privacy statement describe how personal information is collected? Q1b: 1b) Does this privacy statement describe the purpose(s) for which personal information is collected? Q1c: 1c) Does this privacy statement inform individuals whether their personal information is made available to third parties and for what purpose? Q1d: 1d) Does this privacy statement disclose the name of the Applicant Organization's company and location, including contact information regarding practices and handling of personal information upon collection? Q1e: 1e) Does this privacy statement provide information regarding the use and disclosure of an individual's personal information? Q1f: 1f) Does this privacy statement provide information regarding whether and how an individual can access and correct their personal information? Q2: Subject to the Qualifications listed below, at the time of collection of personal information (whether directly or through the use of third parties acting on your behalf), do you provide notice that such information is being collected? Q3: Subject to the Qualifications listed below, at the time of collection of personal information (whether directly or through the use of third parties acting on your behalf), do you indicate the purpose(s) for which personal information is being collected? Q4: Subject to the Qualifications listed below, at the time of collection of personal information, do you notify individuals that their personal information may be shared with third parties?
貳、查詢或請求閱覽（個資法第 3 條第 1 款）				
◆ 個資法第 27 條第 1 項（安全措施：驗證身份）	非公務機關保有個人資料檔案者，應採行適當之安全措施，防止個人資料被竊取、竄改、毀損、滅失或洩漏。	◆ 施行細則第 12 條第 2 項第 5 款： 五、個人資料蒐集、處理及利用之內部管理程序。	個人資料處理活動紀錄	[Access and Correction] Q36: Upon request, do you provide confirmation of whether or not you hold personal information about the requesting individual? Q37: Upon request, do you provide individuals access to the personal information that you hold about them? 37a) Do you take steps to confirm the identity of the individual requesting access? 37b) Do you provide access within a reasonable time frame following an individual's request for access? 37c) Is information communicated in a reasonable manner that is generally understandable? 37d) Is information provided in a way that is compatible with the regular form of interaction with the individual? 37e) Do you charge a fee for providing access?
參、請求製給複製本（個資法第 3 條第 2 款）				

個資法依據	個資法條文	施行細則對應條文	佐證文件／資料	GCBPR Program Requirements
◆ 個資法第 27 條第 1 項（複製傳輸安全）	非公務機關保有個人資料檔案者，應採行適當之安全措施，防止個人資料被竊取、竄改、毀損、滅失或洩漏。	◆ 施行細則第 12 條第 2 項第 5 款： 五、個人資料蒐集、處理及利用之內部管理程序。（複製本製作與傳遞之安全管控）	個人資料處理活動紀錄	[Access and Correction] Q37: Upon request, do you provide individuals access to the personal information that you hold about them? 37a) Do you take steps to confirm the identity of the individual requesting access? 37b) Do you provide access within a reasonable time frame following an individual's request for access? 37c) Is information communicated in a reasonable manner that is generally understandable? 37d) Is information provided in a way that is compatible with the regular form of interaction with the individual? 37e) Do you charge a fee for providing access?
			資訊傳輸安全規則及協議文件	[Security Safeguards] Q27: Describe the physical, technical and administrative safeguards you have implemented to protect personal information against risks such as loss or unauthorized access, destruction, use, modification or disclosure of information or other misuses. Q30: Have you implemented safeguards that are proportional to the likelihood and severity of the harm threatened, the sensitivity of the information, and the context in which it is held, through: 30a) Employee training and management or other safeguards? 30b) Information systems and management, including network and software design, as well as information processing, storage, transmission, and disposal? 30c) Detecting, preventing, and responding to attacks, intrusions, or other security failures? 30d) Physical security?
肆、請求補充或更正（個資法第 3 條第 3 款）				
◆ 個資法第 11 條第 1 項（正確性維護主動義務）	公務機關或非公務機關應維護個人資料之正確，並應主動或依當事人之請求，補充或更正之。	◆ 施行細則第 19 條： 當事人依本法第十一條第一項規定向公務機關或非公務機關請求更正或補充其個人資料時，應為適當之釋明。	存取、更正及刪除程序文件	[Access and Correction] Q38: Do you permit individuals to challenge the accuracy of their information, and to have it rectified, completed, amended and/or deleted? 38a) Are your access and correction mechanisms presented in a clear and conspicuous manner? 38b) If an individual demonstrates that personal information about them is incomplete or incorrect, do you make the requested correction, addition, or where appropriate, deletion? 38c) Do you make such corrections or deletions within a reasonable time frame following an individual's request? 38d) Do you provide a copy of the corrected personal information, or confirmation that it has been corrected or deleted? 38e) If access or correction is refused, do you notify the individual with an explanation and contact information for further inquiries?
◆ 個資法第 11 條第 3 項（正確性爭議時之停止利用）	個人資料正確性有爭議者，應主動或依當事人之請求停止處理或利用。但因執行職務或業務所必須，或經當事人書面同意者，不在此限。	◆ 施行細則第 14 條（§11(3)但書之書面同意形式）： 本法第十一條第二項及第三項但書所定當事人書面同意之方式，依電子簽章法之規定，得以電子文件為之。（本款適用於：當事人書面同意繼續處理或利用，作為停止義務之但書例外）	個人資料處理活動紀錄	[Integrity of Personal Information] Q21: Do you take steps to verify that the personal information held by you is up to date, accurate and complete, to the extent necessary for the purposes of use? Q22: Do you have a mechanism for correcting inaccurate, incomplete and outdated personal information to the extent necessary for purposes of use?
◆ 個資法第 4 條	受公務機關或非公務機關委託蒐集、處理或利	◆ 施行細則第 8 條：	委外處理者問責機制文件	[Integrity of Personal Information]

個資法依據	個資法條文	施行細則對應條文	佐證文件／資料	GCBPR Program Requirements
(委託關係—更正通知義務)	用個人資料者，於本法適用範圍內，視同委託機關。	委託機關應定期確認受託者執行之狀況，並將確認結果記錄之。		Q23: Where inaccurate, incomplete or out-of-date information will affect the purposes of use and corrections are made subsequent to the transfer of the information, do you communicate the corrections to personal information processors, agents, or other service providers to whom the personal information was transferred? Q24: Where inaccurate, incomplete or out-of-date information will affect the purposes of use and corrections are made subsequent to the disclosure of the information, do you communicate the corrections to other third parties to whom the personal information was disclosed? Q25: Do you require personal information processors, agents, or other service providers acting on your behalf to inform you when they become aware of information that is inaccurate, incomplete, or out-of-date?
伍、請求停止蒐集、處理或利用（個資法第 3 條第 4 款）				
◆ 個資法第 11 條第 3 項（正確性爭議時之停止義務）	個人資料正確性有爭議者，應主動或依當事人之請求停止處理或利用。但因執行職務或業務所必須，或經當事人書面同意者，不在此限。	◆ 施行細則第 14 條（§11(3)但書之書面同意形式）： 本法第十一條第二項及第三項但書所定當事人書面同意之方式，依電子簽章法之規定，得以電子文件為之。	個人資料處理活動紀錄	[Choice] Q15: Subject to the Qualifications described below, do you provide a mechanism for individuals to exercise choice in relation to the use of their personal information? Q20: What mechanisms are in place so that choices, where appropriate, can be honored in an effective and expeditious manner?
◆ 個資法第 27 條第 1 項（停止執行之技術措施）	非公務機關保有個人資料檔案者，應採行適當之安全措施，防止個人資料被竊取、竄改、毀損、滅失或洩漏。	◆ 施行細則第 12 條第 2 項第 5 款： 五、個人資料蒐集、處理及利用之內部管理程序。（停止指令之技術執行及系統設定程序）	存取控制政策文件	[Security Safeguards] Q27: Describe the physical, technical and administrative safeguards you have implemented to protect personal information against risks such as loss or unauthorized access, destruction, use, modification or disclosure of information or other misuses. Q30: Have you implemented safeguards that are proportional to the likelihood and severity of the harm threatened, the sensitivity of the information, and the context in which it is held, through: 30a) Employee training and management or other safeguards? 30b) Information systems and management, including network and software design, as well as information processing, storage, transmission, and disposal? 30c) Detecting, preventing, and responding to attacks, intrusions, or other security failures? 30d) Physical security?
陸、請求刪除（個資法第 3 條第 5 款）				
◆ 個資法第 11 條第 4 項（目的消失時之刪除義務）	個人資料蒐集之特定目的消失或期限屆滿時，應主動或依當事人之請求，刪除、停止處理或利用該個人資料。但因執行職務或業務所必須或經當事人書面同意者，不在此限。	◆ 施行細則第 20 條、第 21 條：特定目的消失之定義及因執行職務或業務所必須之情形。	資料保留政策／程序	[Access and Correction] Q38: Do you permit individuals to challenge the accuracy of their information, and to have it rectified, completed, amended and/or deleted? 38a) Are your access and correction mechanisms presented in a clear and conspicuous manner? 38b) If an individual demonstrates that personal information about them is incomplete or incorrect, do you make the requested correction, addition, or where appropriate, deletion? 38c) Do you make such corrections or deletions within a reasonable time frame following an individual's request? 38d) Do you provide a copy of the corrected personal information, or confirmation

個資法依據	個資法條文	施行細則對應條文	佐證文件／資料	GCBPR Program Requirements
				that it has been corrected or deleted? 38e) If access or correction is refused, do you notify the individual with an explanation and contact information for further inquiries?
◆ 個資法第 27 條第 1 項（刪除之技術安全措施）	非公務機關保有個人資料檔案者，應採行適當之安全措施，防止個人資料被竊取、竄改、毀損、滅失或洩漏。	◆ 施行細則第 12 條第 2 項第 5 款：五、個人資料蒐集、處理及利用之內部管理程序。（刪除應採符合安全標準之方式，確保無從復原）	資料保留及安全銷毀政策	[Security Safeguards] Q31: Have you implemented a policy for secure disposal of personal information?
◆ 個資法第 11 條第 5 項（刪除後通知第三方）	依第三條第五款規定刪除個人資料者，應通知曾依第三條第一款至第四款規定接受該個人資料揭露之第三人，請求其配合刪除。但通知顯有困難或費用過鉅者，不在此限。	—	委外處理者問責機制文件	[Uses of Personal Information] Q10: Do you disclose personal information you collect (whether directly or through the use of third parties acting on your behalf) to other personal information controllers? Q24: Where inaccurate, incomplete or out-of-date information will affect the purposes of use and corrections are made subsequent to the disclosure of the information, do you communicate the corrections to other third parties to whom the personal information was disclosed?
柒、DSAR 紀錄保存與稽核（適用所有五項權利）				
◆ 個資法第 22 條第 1、4 項（配合主管機關調查）	中央目的事業主管機關或直轄市、縣（市）政府為執行資料檔案安全維護、業務終止資料處理方法、國際傳輸限制或其他例行性業務檢查而認有必要或有違反本法規定之虞時，得派員攜帶執行職務證明文件，進入檢查，並得命相關人員為必要之說明、配合措施或提供相關證明資料。對於前項之進入、檢查或處分，非公務機關及其相關人員不得規避、妨礙或拒絕。	◆ 施行細則第 12 條第 2 項第 9 款、第 10 款：資料安全稽核機制；使用紀錄、軌跡資料及證據保存。	稽核計畫及稽核結果紀錄	[Accountability] Q39: What measures do you take to ensure compliance with the Global CBPR Privacy Principles? (Internal guidelines or policies / Contracts / Compliance with applicable industry or sector laws and regulations / Compliance with self-regulatory Applicant Organization code and/or rules / Other) Q45: Do you have procedures in place for responding to judicial or other government subpoenas, warrants or orders, including those that require the disclosure of personal information?
◆ 個資法第 27 條第 1 項（安全維護義務）	非公務機關保有個人資料檔案者，應採行適當之安全措施，防止個人資料被竊取、竄改、毀損、滅失或洩漏。	◆ 施行細則第 12 條第 2 項第 10 款：十、使用紀錄、軌跡資料及證據保存。	稽核計畫及稽核結果紀錄	[Security Safeguards] Q27: Describe the physical, technical and administrative safeguards you have implemented to protect personal information against risks such as loss or unauthorized access, destruction, use, modification or disclosure of information or other misuses. Q32: Have you implemented measures to detect, prevent, and respond to attacks, intrusions, or other security failures? Q33: Do you have processes in place to test the effectiveness of the safeguards referred to in Q32? Q34: Do you use third-party certifications or other risk assessments?
◆ 個資法第 27 條第 1、2 項（安全維護計畫）	中央目的事業主管機關得指定非公務機關訂定個人資料檔案安全維護計畫或業務終止後個人資料處理方法。計畫應涵蓋當事人權利行使程序。	◆ 施行細則第 12 條第 2 項第 11 款：十一、個人資料安全維護之整體持續改善。	不符合事項及矯正措施紀錄	[Accountability] Q40: Have you appointed an individual(s) to be responsible for your overall compliance with the Global CBPR Privacy Principles? Q41: Do you have procedures in place to receive, investigate and respond to privacy-related complaints? Q42: Do you have procedures in place to ensure individuals receive a timely response to their complaints? Q43: If YES to Q42, does this response include an explanation of

個資法依據	個資法條文	施行細則對應條文	佐證文件／資料	GCBPR Program Requirements
				remedial action relating to their complaint?

★ 回應期限說明：個資法第 13 條規定 15 日內為准駁決定，必要時得延長 15 日（最長合計 30 日），應以書面通知延長原因。期限計算依「收受請求後」起算（初日不算入）。

★ 拒絕事由說明：第 3 條第 4 款（停止）及第 5 款（刪除）得依第 10 條第 2 項四款事由拒絕；第 1 款（查詢）、第 2 款（複製）、第 3 款（更正）之拒絕須有個別合法依據。拒絕決定均應書面敘明理由並留存紀錄。

* 供法務使用・僅供內部參考・搭配 01 AI Prompt 路徑 B 使用（不需 02 法規盤點對照表）

★ Response deadline: Article 13 requires a decision within 15 days of receipt, extendable once by up to 15 days with written notice of the reason.

★ Grounds for refusal: requests under Article 3(4) (cessation) and 3(5) (deletion) may be refused under the four grounds in Article 10(2); requests under 3(1)-(3) (access, copy, correction) require independent legal grounds for refusal. All refusals must be in writing with reasons and retained as records.

* For legal/compliance professional use only・Internal reference only・Used together with 01 AI Prompt Path B (Document 02 not required)